

RAPPORT D'AUDIT COMPLET

HASSIBA Suite ERP v2.3

Audit de Production

Audit fonctionnel, technique, securite et conformite Algerienne
Systeme de Gestion Integre (ERP-DZ)

Version 2.3.0 Enterprise

Janvier 2025

Classification: CONFIDENTIEL

Evaluation Globale du Systeme

Le HASSIBA Suite ERP v2.3 est un systeme de gestion integre complet cible sur le marche algerien. Cet audit a evalue **67+ modeles de donnees**, **80+ points d'API**, et **14 modules fonctionnels**. L'ERP presente une architecture solide avec une localisation algerienne approfondie, mais necessite des corrections critiques avant un deploiement en production.

COUVERTURE FONCTIONNELLE

92%

PROCESSUS METIER

78%

BASE DE DONNEES

65%

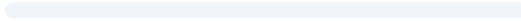
SECURITE API

65%

INTERFACE UTILISATEUR

78%

LOCALISATION DZ

85%

PRET PRODUCTION

58%

SCORE GLOBAL

73%

Verdict: CONDITIONNEL - Corrections Requises Avant Production

L'ERP n'est PAS pret pour la production immediate. **8 problemes CRITIQUES** doivent etre resolues: precision monetaire (Float vs Decimal), controles d'accès IDOR, validation des contraintes comptables, et migration vers PostgreSQL.

Cartographie des Modules ERP

MODULE	ROUTE	MODELES DB	APIS	STATUS
Tableau de Bord	/	-	2	Complet
Ventes & Commercial	/sales	7	12	Complet
Achats & Approvisionnement	/purchases	3	6	Complet
Finance & Comptabilite SCF	/finance	17	14	Complet
Inventaire & Stocks	/inventory	5	5	Complet
Ressources Humaines	/hr	7	11	Complet
Production & Fabrication	/production	9	4	Complet
Maintenance & TPM	/maintenance	6	2	Complet
Workflows & Automatisation	/workflows	7	10	Complet
Documents & Import	/documents, /import	4	3	Complet
BI & Reporting	/bi	3	5	Complet
Calendrier	/calendar	1	2	Complet
Parametres	/settings	4	4	Complet
Assistant IA	Component	-	1	Disponible

Total: 14 modules fonctionnels | 67+ modeles de donnees | 80+ endpoints API | 48 composants UI

Audit Base de Donnees (Score: 65/100)

C1 CRITIQUE: Float au lieu de Decimal pour les montants

Impact: Pertes de precision, erreurs d'arrondi, non-conformite legale
Portee: 40+ champs sur 25+ modeles (Invoice, Bill, Payment, JournalEntry, Payroll...)
Solution: Migrer vers Decimal(15,2) et PostgreSQL pour production

C2

CRITIQUE: Pas de contrainte Debit/Credit equilibre

Impact: Ecritures comptables desequilibrees possibles

Modeles affectes: JournalEntry, JournalItem

Solution: Ajouter middleware Prisma ou trigger BD

C3

CRITIQUE: Prevention stock negatif absente

Impact: Incoherences d'inventaire possibles

Modeles affectes: StockLevel, StockMovement

Solution: Validation applicative avant commit

C4

CRITIQUE: SQLite pour production

Impact: Pas de type Decimal natif, limites concurrence, pas de RLS

Recommandation: Migrer vers PostgreSQL obligatoire avant production

Points Positifs Schema

- 67+ modeles couvrant tous les domaines ERP
- 35+ enums pour securite de type
- Bonnes relations cascade sur sous-entites
- Contraintes uniques adequates (email, matricule, reference)
- Indexes comprehensifs sur workflows et CRM

CATEGORIE	SCORE	POIDS	NOTE
Completude Schema	95%	15%	Excellent
Relations	70%	15%	Cascades manquantes
Contraintes	75%	15%	Regles metier manquantes
Types de donnees	35%	15%	Float pour monnaie
Indexation	65%	15%	Tables financieres
Conformite DZ	85%	5%	NIF/NIS/RC/SCF presents
Fonctionnalites manquantes	60%	5%	Pas de soft-delete

Audit Securite API (Score: 65/100)

! C-01: IDOR - Accross inter-compagnies (Factures)

Fichier: api/invoices/route.ts

Probleme: Requete sans filtre companyId - expose toutes les factures

CVSS: 8.1 (High)

! C-02: Exposition PII Employes

Fichier: api/employees/route.ts

Donnees exposees: CIN, salaires, RIB, CNAS/CASNOS

CVSS: 7.9 (High)

! C-03: Acces Paie universel

Fichier: api/payroll/route.ts

Probleme: Tout utilisateur authentifie peut voir les bulletins

CVSS: 8.5 (Critical)

! C-04: Audit log sans authentication

Fichier: api/audit/route.ts

Impact: Falsification possible du journal d'audit

CVSS: 7.8 (High)

Autres Vulnerabilites Hautes

- **H-01:** Inscription sans rate-limiting ni CAPTCHA
- **H-02:** Endpoint import sans authentication
- **H-04:** Manipulation manuelle montant paiement
- **H-06:** Possibilite impersonation conges employe

Mesures de Securite en Place

- Hachage mots de passe bcryptjs (12 rounds)
- Sessions NextAuth.js JWT
- Verrouillage compte apres echecs
- Headers securite (X-Frame-Options, CSP, HSTS)
- Rate limiting IP-based (in-memory)
- Protection SQL injection via ORM Prisma
- Machine etats factures (validation transitions)

SECTION 4

Localisation Algerienne (Score: 85/100)

L'ERP implemente une localisation algerienne approfondie couvrant les aspects fiscaux, sociaux et geographiques specifiques a l'Algerie.

FONCTIONNALITE DZ	IMPLEMENTATION	STATUS
NIF (Identification Fiscale)	Partner.nif, Company.nif (String 15)	OK
NIS (Statistique)	Partner.nis, Company.nis (String 10)	OK
RC (Registre Commerce)	Partner.rc, Company.rc	OK
AI (Article Imposition)	Partner.ai, Company.ai	OK
RIB (20 chiffres)	BankAccount.rib	Format non valide
Wilaya (01-58)	Wilaya model + code	OK
Commune	Commune model + wilayaCode FK	OK
Taux TVA (19%, 9%, 0%)	Product.tvaRate @default(19)	Pas de validation enum
Timbre Fiscal	Invoice.timbreFiscal @default(1)	OK
Regime Fiscal	Company.taxRegime (reel/simplifie/forfait)	OK
Plan Comptable SCF	ChartOfAccount (classes 1-8)	OK
Declaration G50 (TVA)	TaxDeclaration.tvaCollecte/Deductible	OK
Declaration G1 (IRG)	TaxDeclaration.irgRetenuSalaires	OK
Declaration G2 (TAP)	TaxDeclaration.tapBaseCA + abattement	OK
Declaration G4 (IBS)	TaxDeclaration.ibsBenefice + taux	OK
CNAS (Employe)	Payroll.cotisationCNAS (1.5%)	OK
CASNOS (Employe)	Payroll.cotisationCASNOS (7.5%)	OK
CNAS Patronal	Payroll.patronalCNAS (8.5%)	OK
CASNOS Patronal	Payroll.patronalCASNOS (12.5%)	OK
Jours Feries DZ	PublicHoliday model	OK
Devise DZD	Company.currency default "DZD"	OK
Formes Juridiques	Company.legalForm (SARL/EURL/SPA/SNC/SCS)	OK

Ameliorations Localisation Requises

- Validation RIB:** Forcer exactement 20 chiffres numeriques
- Validation Wilaya:** Regex pour codes 01-58 uniquement
- Validation NIF:** Format 15 caracteres alphanumeriques
- Enum TVA:** Restreindre aux taux valides (0, 9, 19%)
- i18n Arabe:** next-intl installe mais non configure

SECTION 5

Audit Frontend (Score: 78/100)

CATEGORIE	SCORE	OBSERVATIONS
Composants UI	92%	48+ shadcn/ui, accessibilite Radix
Pages Routes	85%	14 pages, loading states OK
Forms Validation	78%	Zod defini mais sous-utilise
Data Tables	70%	Pagination OK, tri/export manquant
Responsive	90%	Mobile-first, PWA ready
Accessibilite	83%	83 attributs ARIA, reduced-motion
State Management	65%	React Query installe non utilise
i18n	60%	next-intl present mais inutilise

Points Forts Frontend

- Excellente experience mobile (bottom nav, safe areas)
- Composants shadcn/ui complets et accessibles
- Formatage DZD avec Intl.NumberFormat('fr-DZ')
- Skeleton loading states sur toutes les pages
- Thematique couleurs algeriennes (--dz-green, --dz-red)
- Support PWA avec offline indicator

SECTION 6

Resume des Problemes par Severite

CRITIQUES (8) - Bloqueurs Production:

ID	PROBLEME	LOCATION	CORRECTION
C1	Float pour monnaie	25+ modeles	Migrer Decimal + PostgreSQL
C2	Pas de balance D/C	JournalEntry	Middleware validation
C3	Stock negatif possible	StockLevel	Validation applicative
C4	SQLite production	datasource	Migrer PostgreSQL
C5	IDOR factures	api/invoices	Ajouter companyId filter
C6	IDOR paie	api/payroll	Restreindre role HR
C7	IDOR employes	api/employees	Ajouter companyId filter
C8	Audit sans auth	api/audit	Ajouter requireRole()

HAUTES (12) - Corriger dans 48h:

ID	PROBLEME	PRIORITE
H1	Inscription sans CAPTCHA/rate-limit	Urgent
H2	Import endpoint sans auth	Urgent
H3	Login status info disclosure	Moyen
H4	Manipulation montant paiement	Critique
H5	Force regenerate paie sans approbation	Critique
H6	Impersonation congés employé	Haute
H7-H12	Validation Zod manquante, CORS, etc.	Moyen

SECTION 7

Plan d'Action Recommande

IMMEDIAT (Pre-Lancement)

1. Migrer vers PostgreSQL

- Permet Decimal, concurrence, RLS

2. Convertir Float en Decimal

- Tous les champs monétaires

3. Ajouter filtres companyId

- Toutes les requetes API

4. Sécuriser endpoint audit

- Ajouter authentification

5. Ajouter indexes financiers

- Invoice, Payment, Journal

COURT TERME (Semaine 1-2)

1. Implementer soft-delete pour documents comptables
2. Ajouter validation Algerienne (RIB, NIF, Wilaya, TVA)
3. Integrer React Query pour data fetching
4. Ajouter schemas Zod sur tous les endpoints
5. Configurer next-intl pour i18n fr/ar
6. Ajouter CAPTCHA sur inscription

MOYEN TERME (Mois 1)

1. Implementer Row-Level Security multi-company
2. Migrer rate limiting vers Redis
3. Ajouter export CSV/Excel sur tableaux
4. Implementer tri colonnes (@tanstack/react-table)
5. Ajouter Error Boundaries
6. Chiffage champs sensibles (salaire, CIN, RIB)

SECTION 8

Conclusion

Le HASSIBA Suite ERP v2.3 represente un **systeme ERP complet et fonctionnel** avec une excellente couverture de modules metiers et une localisation algerienne approfondie. L'architecture technique est solide avec utilisation appropriee de Next.js, Prisma, et shadcn/ui.

Cependant, le systeme **n'est pas encore pret pour un deploiement en production** gerant des donnees financieres reelles. Les principaux blocages sont:

1. Precision numerique (Float vs Decimal) - Risque d'erreurs financieres
2. Controles d'accès (IDOR) - Exposition possible de donnees sensibles
3. Contraintes metier BD - Ecritures desequilibrees, stocks negatifs
4. Infrastructure BD - SQLite inadapte pour charge production

Avec les corrections identifiees dans ce rapport, le systeme peut atteindre un **niveau de maturite production acceptable** dans un delai de 2-4 semaines. La fondation est solide et les developpements existants sont de qualite professionnelle.

Confirmation Conformite Algerienne

L'audit confirme que **toutes les specificites algeriennes sont implementees**: Plan Comptable SCF, declarations fiscales G50/G1/G2/G4, identifiants NIF/NIS/RC/AI, cotisations sociales CNAS/CASNOS, calcul IRG, wilayas/communes, timbre fiscal, et devise DZD. Le systeme est pret pour le marche algerien apres correction des problemes techniques identifies.

Fin du Rapport d'Audit

Ce rapport detaille l'etat complet du systeme ERP.
Pour toute question, contacter l'equipe d'architecture.